CHƯƠNG 1. NGUỒN DỮ LIỆU VÀ QUY TẮC ÁNH XẠ MITRE ATT&CK

A.1 Thống kê mẫu lành tính theo nguồn

Bảng 1.1 liệt kê 13 nguồn thu thập mẫu lành tính, gồm bảy phiên bản Windows khác nhau từ ISO gốc của Microsoft và sáu nguồn phần mềm hợp pháp bên ngoài.

STT	Nguồn	Số mẫu
1	Windows 10 LTSC 2021 (en-US x64)	18.009
2	Windows 11 Consumer 25H2 (en-US x64)	21.540
3	Windows Server 2022 (en-US x64)	15.801
4	Windows Server 2016 (en-US x64)	12.168
5	Windows Server 2019 (en-US x64)	12.875
6	Windows 8.1 Update 1 (en-US x64)	10.856
7	Windows 7 SP1 Ultimate (en-US x64)	8.821
8	Windows 10 22H2 (en-US x64)	5.275
9	Chocolatey packages (batch 1)	1.813
10	Chocolatey packages (batch 2)	1.091
11	Sysinternals Suite 2025-03	405
12	Nirsoft utilities collection	505
13	GitHub open-source releases	843
	Tổng	**110.002**

Bảng 1.1: Thống kê mẫu lành tính (benign) theo nguồn.

A.2 Thống kê mẫu mã độc theo nguồn

Bảng 1.2 liệt kê bốn tập VirusShare và tập MalwareBazaar được thu thập làm mẫu mã độc.

STT	Nguồn	Số mẫu
1	VirusShare_00499	31.042
2	VirusShare_00495	32.891
3	VirusShare_00483	38.536
4	VirusShare_00480	28.603
5	MalwareBazaar (nhiều họ mã độc)	1.404
	Tổng	**132.476**

Bảng 1.2: Thống kê mẫu mã độc theo nguồn.

A.3 Sysmon Event ID được theo dõi

Bảng 1.3 liệt kê toàn bộ 23 Event ID Sysmon được ghi nhận trong phiên phân tích cùng nhóm hành vi tương ứng.

Event ID	Nhóm hành vi	Mô tả
1	Tiến trình	Tạo tiến trình
2	Tệp	Thay đổi thời gian tạo tệp
3	Mạng	Kết nối mạng
5	Tiến trình	Kết thúc tiến trình
6	Khác	Nạp driver
7	DLL	Nạp thư viện động
8	Tiêm mã	Tạo luồng từ xa (remote thread)
9	Khác	Đọc thô đĩa cứng
10	Tiêm mã	Truy cập tiến trình khác
11	Tệp	Tạo tệp
12, 13, 14	Registry	Tạo / ghi / xóa khóa registry
15	Tệp	Tạo luồng dữ liệu thay thế (ADS)
17, 18	Named pipe	Tạo / kết nối named pipe
19, 20, 21	WMI	Đăng ký WMI filter, consumer, binding
22	DNS	Truy vấn DNS
23, 26	Tệp	Xóa tệp
25	Tiêm mã	Giả mạo tiến trình

Bảng 1.3: Các Sysmon Event ID được theo dõi và nhóm hành vi tương ứng.

A.4 Các luật ánh xạ MITRE ATT&CK đã triển khai

Bảng 1.4 liệt kê toàn bộ 23 luật ánh xạ MITRE ATT&CK được triển khai trong bộ phân tích hành vi. Bốn kỹ thuật T1071.001, T1566.001, T1070.007 và T1568.002 được đánh mức tin cậy trung bình do tín hiệu kích hoạt có thể xuất hiện trong hoạt động bình thường; các kỹ thuật còn lại được đánh mức cao.

Kỹ thuật	Tên	Tín hiệu kích hoạt
T1003.001	LSASS Memory	Process access nhắm vào `lsass.exe`
T1053.005	Scheduled Task	Ghi vào khóa `ScheduledTask`
T1055	Process Injection	Remote thread (EID 8) hoặc process access (EID 10)
T1055.012	Process Hollowing	Giả mạo tiến trình (EID 25)
T1070	Indicator Removal	Xóa tệp log, shadow, backup hoặc .evt
T1070.007	Clear Persistence	Xóa khóa registry
T1071.001	App. Layer Protocol	Kết nối ra IP công khai ngoài mạng nội bộ
T1071.003	Named Pipe C2	Named pipe khớp từ khóa C2 đã biết
T1090.003	Multi-hop Proxy	Truy vấn DNS tên miền `.onion`
T1218	Signed Binary Proxy Exec.	Tiến trình là công cụ LOLBin
T1490	Inhibit System Recovery	Thao tác tệp shadow, VSS hoặc backup
T1543.003	Windows Service	Ghi vào khóa `Services`
T1546.003	WMI Event Subscription	Đăng ký WMI filter, consumer, binding
T1546.010	AppInit DLLs	Ghi vào khóa `AppInit_DLLs`
T1546.012	IFEO Injection	Ghi vào `Image File Execution`
T1547.001	Registry Run Keys	Khóa `CurrentVersion\Run` hoặc Startup
T1547.004	Winlogon Helper DLL	Ghi vào khóa `Winlogon`
T1547.005	Security Support Provider	Ghi vào khóa `SecurityProviders`
T1547.008	LSASS Driver	Ghi vào `Lsa\Notification`
T1566.001	Spearphishing Attachment	Tiến trình cha là ứng dụng Office hoặc Acrobat
T1568.002	Domain Generation Alg.	Entropy Shannon nhãn phụ $> 3{,}5$ bit và độ dài ≥ 12 ký tự
T1571	Non-Standard Port	Kết nối đến cổng C2 (4444, 1337, 8888, 9999, 31337, 8080, 8443)
T1620	Reflective Code Loading	Assembly .NET nạp qua `System.Reflection`

Bảng 1.4: Các luật ánh xạ MITRE ATT&CK được triển khai trong bộ phân tích hành vi.

A.6 Endpoint và sự kiện SSE của server web demo

Bảng 1.5 liệt kê bảy endpoint REST của server; Bảng 1.6 mô tả chín loại sự kiện trong luồng SSE.

Endpoint	Phương thức	Chức năng
`/`	GET	Phục vụ trang giao diện (`index.html`)
`/api/analyze`	POST	Nhận tệp mẫu và tham số; tạo `job_id`, lưu vào `uploads/`, khởi chạy pipeline trong luồng nền
`/api/jobs/<id>/stream`	GET	Luồng SSE; phát sự kiện pipeline theo thời gian thực
`/api/jobs/<id>/stop`	POST	Đặt cờ dừng, đẩy `stopped`+`eof` vào hàng đợi, tắt VM qua `VMManager`
`/api/jobs/<id>`	GET	Trả về trạng thái và kết quả cuối của một job
`/api/reports`	GET	Liệt kê tệp JSON trong `results/pipeline_runs/`, sắp xếp theo thời gian giảm dần
`/api/report/<filename>`	GET	Đọc và trả về nội dung một báo cáo JSON

Bảng 1.5: Toàn bộ endpoint của server web demo.

Loại sự kiện	Nội dung
`ping`	Giữ kết nối; client bỏ qua
`started`	Pipeline bắt đầu; kèm tên tệp mẫu
`stage_start`	Giai đoạn bắt đầu; kèm số thứ tự `n` (1–12) và tên
`stage_done`	Giai đoạn hoàn thành; kèm số thứ tự `n`
`log`	Dòng nhật ký; kèm cấp độ (INFO/WARNING/ERROR) và nội dung
`done`	Pipeline hoàn tất; kèm toàn bộ báo cáo JSON
`stopped`	Pipeline bị người dùng dừng
`error`	Pipeline gặp lỗi; kèm thông báo lỗi
`eof`	Kết thúc luồng; client đóng `EventSource`

Bảng 1.6: Chín loại sự kiện SSE trong luồng `/api/jobs/<id>/stream`.

A.7 Cấu hình bộ chuẩn hóa SilkETW

Bảng 1.7 liệt kê tám tiến trình thuộc `_DOTNET_NOISE_PROCS` bị loại khỏi đầu ra SilkETW; Bảng 1.8 liệt kê bảy từ khóa namespace thuộc `_SUSPICIOUS_NS` dùng để đánh dấu nghi ngờ.

Tiến trình	Lý do loại trừ
`msbuild`, `devenv`, `dotnet`, `vstest`, `testhost`	Công cụ phát triển .NET, không phải đ tượng phân tích
`silketw`	Tránh tự tham chiếu của công cụ thu th
`powershell`, `pwsh`	Sysmon EID 1 đã ghi đầy đủ khi mẫu g shell

Bảng 1.7: Tám tiến trình trong `_DOTNET_NOISE_PROCS` bị loại khỏi đầu ra bộ chuẩn hóa SilkETW.

Từ khóa namespace	Hành vi phản ánh
`dynamicClass`	Tạo kiểu .NET động tại thời điểm chạy
`Invoke`	Gọi phương thức qua Reflection
`Emit`	Tự sinh mã IL lúc chạy (IL Emit)
`Reflection`	Truy cập metadata và bộ nhớ qua introspection
`RunspaceFactory`	Tạo môi trường PowerShell trong bộ nhớ
`AmsiUtils`	Vô hiệu hóa Antimalware Scan Interface
`System.Net`	Kết nối mạng từ bên trong .NET Runtime

Bảng 1.8: Bảy từ khóa trong `_SUSPICIOUS_NS` dùng đánh dấu sự kiện SilkETW nghi ngờ.

A.8 Endpoint của Agent HTTP trong máy ảo

Bảng 1.9 liệt kê toàn bộ 11 endpoint của Agent HTTP chạy trong máy ảo Windows.

Endpoint	Phương thức	Chức năng
`/health`	GET	Kiểm tra Agent đã khởi động; trả về trạng thái và thời gian hoạt động
`/execute`	POST	Khởi chạy tệp mẫu dưới dạng tiến trình mới; trả về PID
`/shell`	POST	Thực thi lệnh shell tùy ý, đồng bộ hoặc nền (`async=true`)
`/upload`	POST	Ghi nội dung văn bản vào đường dẫn tùy chỉnh trên guest
`/read`	GET	Đọc nội dung tệp từ hệ thống tệp guest; Bridge dùng để poll log Sysmon
`/process_tree/{pid}`	GET	Liệt kê toàn bộ PID con và cháu của tiến trình gốc
`/process/{pid}`	GET	Kiểm tra trạng thái và thời gian chạy của một PID cụ thể
`/status`	GET	Trạng thái tổng thể tiến trình hiện tại; tự dừng nếu vượt timeout
`/stop`	POST	Dừng tiến trình đang chạy theo PID
`/logs`	GET	Trả về nhật ký nội bộ của Agent (sự kiện execute, stop, . . .)
`/screenshot`	GET	Chụp màn hình guest, trả về ảnh dạng Base64 PNG

Bảng 1.9: Toàn bộ endpoint của Agent HTTP trong máy ảo.

A.9 Ánh xạ sự kiện chuẩn hóa vào nhóm hành vi

Bảng 1.10 liệt kê 11 nhóm hành vi và các loại sự kiện chuẩn hóa tương ứng dùng trong mô-đun xây dựng chuỗi hành vi.

Nhóm hành vi	Loại sự kiện
Tiến trình	Tạo tiến trình, kết thúc tiến trình
Tiêm mã	Truy cập tiến trình khác, tạo luồng từ xa, giả mạo tiến trình
Nạp thư viện động	Nạp DLL
Tệp	Tạo tệp, xóa tệp, xóa tệp có ghi nhận, thay đổi thời gian tệp, tạo ADS
Registry	Tạo khóa, ghi khóa, xóa khóa
Mạng	Kết nối mạng
DNS	Truy vấn DNS
Named pipe	Tạo pipe, kết nối pipe
WMI	Đăng ký WMI filter, consumer, binding
.NET Runtime	Nạp assembly .NET
Khác	Nạp driver, đọc đĩa thô

Bảng 1.10: Ánh xạ 24 loại sự kiện chuẩn hóa vào 11 nhóm hành vi.

A.10 Cấu trúc báo cáo JSON đầu ra của pipeline

Bảng 1.11 liệt kê tên trường thực tế của từng nhóm trong báo cáo JSON theo thiết kế tại Mục **??**.

Nhóm	Trường JSON
Kết quả phân loại	`verdict`, `confidence`, `ml_label`, `ml_prob`
Thông tin hành vi	`behavioral_chain`, `process_tree`, `narrative`, `mitre_techniques`
Chỉ số xâm phạm	`ioc` (10 danh mục: ips, domains, urls, files_created, files_deleted, registry_keys, commands, named_pipes, injected_pids, hashes)
Thông tin phiên	`metadata`: sha256, file_size, started_at, ended_at, duration_s, stages, event_count, ttp_count, analyzed_at
Cảnh báo và lỗi	`warnings`, `errors`

Bảng 1.11: Cấu trúc báo cáo JSON đầu ra của pipeline.